

CHECKLIST NIS2

Os 10 Requisitos Obrigatórios para Infraestruturas Críticas em 2026

O guia prático para Gestores e CISO que precisam de garantir conformidade antes que as multas cheguem à mesa.

■ Conformidade Legal

■ Gestão de Risco

■ Pronto a Usar

DHS — Systems | Cibersegurança & Compliance

www.dalpinheritage.com · 2026

■ O Problema: O Relógio Está a Contar

A Diretiva NIS2 (Diretiva UE 2022/2555) está em vigor e o prazo de transposição já passou. Em Portugal, organizações de setores críticos — energia, saúde, transportes, água, infraestrutura digital — estão sujeitas a obrigações legais imediatas.

€10M ou 2% faturação Multa máxima por incumprimento grave	24h Para notificar incidentes significativos	72% Das PMEs ainda não iniciam conformidade
---	--	---

O que muda com a NIS2?

■ Responsabilidade Pessoal dos Administradores	Os órgãos de gestão podem ser responsabilizados pessoalmente pelo incumprimento. Já não é 'problema do IT' — é problema do Conselho.
■ Âmbito Alargado	Passa de ~100 para +4.000 entidades em Portugal. Se tem mais de 50 colaboradores ou faturação >€10M em setores essenciais, está abrangido.
■ Sanções Imediatas	A CNCS tem poderes para suspender certificações, impor auditorias obrigatórias e publicar o nome das entidades em incumprimento.

■ **ATENÇÃO:** "Não sabia que estava abrangido" não é defesa legal válida. A ignorância da lei não isenta de responsabilidade.

■ Os 10 Requisitos NIS2 — Checklist de Conformidade

Use esta checklist para avaliar a maturidade atual da sua organização. Para cada requisito, assinale ✓ se estiver implementado, ou deixe em branco para identificar gaps prioritários.

1

GOVERNANÇA E GESTÃO DE RISCO

01

☐

Política de Segurança da Informação

Documento aprovado pela gestão, revisto anualmente, com âmbito, objectivos e responsabilidades claros.

OBRIGATÓRIO

02

☐

Avaliação e Gestão de Risco Formal

Metodologia documentada (ex: ISO 27005, NIST), registo de riscos actualizado e tratamento definido.

OBRIGATÓRIO

03

☐

Responsável NIS2 Nomeado (CISO ou equivalente)

Pessoa com mandato formal, acesso à gestão de topo e autoridade para implementar controlos.

OBRIGATÓRIO

04

☐

Formação e Sensibilização Regular

Programa anual de awareness para todos os colaboradores; registo de participação mantido.

RECOMENDADO

05

☐

Gestão de Activos de Informação

Inventário actualizado de todos os activos críticos (sistemas, dados, aplicações) com owner definido.

OBRIGATÓRIO

■ Os 10 Requisitos NIS2 — Continuação

2 OPERAÇÕES E RESPOSTA A INCIDENTES

- 06

☐

Plano de Resposta a Incidentes (IRP)
Procedimentos documentados, testados pelo menos 1x/ano, com papéis, escalada e comunicação à CNCS.

OBRIGATÓRIO
- 07

☐

Capacidade de Notificação em 24h
Processo interno para detectar, triagear e reportar incidentes significativos dentro do prazo legal.

OBRIGATÓRIO
- 08

☐

Continuidade de Negócio e Recuperação (BCP/DRP)
RTO e RPO definidos para sistemas críticos; testes de failover realizados e documentados.

OBRIGATÓRIO
- 09

☐

Segurança da Cadeia de Abastecimento
Avaliação de risco de fornecedores críticos; cláusulas contratuais de segurança em vigor.

RECOMENDADO
- 10

☐

Testes de Penetração e Auditorias Técnicas
Pentest externo mínimo anual; resultados documentados com plano de remediação e follow-up.

RECOMENDADO

Pontuação	Resultado	Próximo Passo
8–10 ✓	Maturidade Elevada	Auditoria formal para certificar e documentar
5–7 ✓	Em Progresso	Plano de acção priorizado para gaps críticos
0–4 ✓	Exposição Significativa	Diagnóstico urgente com especialista NIS2

■ Matriz de Risco: Onde Estão os Gaps Mais Comuns

Com base em 40+ diagnósticos NIS2 realizados pela Dalpin Heritage, estes são os gaps mais frequentes nas organizações portuguesas:

Domínio	Gap Típico Identificado	Nível Risco	Prioridade
Gestão de Risco	Sem metodologia formal documentada	■ CRÍTICO	1ª
Resposta a Incid.	IRP desactualizado ou nunca testado	■ CRÍTICO	1ª
Notificação	Processo de reporte à CNCS inexistente	■ CRÍTICO	1ª
Continuidade	BCP existe mas DRP não testado em 2+ anos	■ ELEVADO	2ª
Cadeia Abast.	Sem avaliação de risco de fornecedores IT	■ ELEVADO	2ª
Formação	Awareness limitado à área IT	■ MÉDIO	3ª
Activos	Inventário incompleto ou não actualizado	■ MÉDIO	3ª
Pentest	Sem testes técnicos externos no último ano	■ MÉDIO	3ª

■ Os 5 Erros Fatais que Levam ao Incumprimento

Erro 1	Delegar NIS2 apenas ao IT: A diretiva exige envolvimento explícito da gestão de topo. Sem aprovação do Conselho, a conformidade é inválida.
Erro 2	Confundir GDPR com NIS2: São complementares mas distintos. NIS2 foca resiliência operacional; GDPR foca proteção de dados. Ambos são obrigatórios.
Erro 3	Documentação sem implementação real: Ter políticas 'na gaveta' sem evidências de aplicação é considerado incumprimento numa auditoria regulatória.
Erro 4	Ignorar fornecedores e parceiros: Um ataque via supply chain é responsabilidade sua. A NIS2 exige que avalie e monitorize a segurança dos seus fornecedores críticos.
Erro 5	Não testar o plano de resposta a incidentes: Um plano não testado é um plano que falha. A lei exige exercícios regulares e documentados.

■ Caso de Estudo: Redução de Exposição em 90 Dias

Perfil da Empresa
Setor: Operador de Serviços Essenciais (Energia)
Dimensão: 180 colaboradores | Faturação: €45M
Situação inicial: 3/10 requisitos NIS2 implementados

Mês 1	Diagnóstico & Gap Analysis Realizámos o NIS2 Readiness Assessment completo. Identificámos 7 gaps críticos, priorizámos os 3 com maior impacto legal. Entregámos relatório executivo ao Conselho de Administração.
Mês 2	Implementação dos Controlos Críticos Desenvolvemos o IRP (Incident Response Plan), implementámos processo de notificação CNCS, e realizámos o primeiro exercício de simulação de incidente.
Mês 3	Documentação e Formação Completámos o inventário de activos, implementámos programa de awareness para todos os colaboradores, e entregámos dossier de conformidade NIS2 pronto para auditoria.

Resultado	Antes	Depois (90 dias)
Score NIS2	3 / 10	8 / 10
Gaps Críticos	7 identificados	1 residual (em curso)
Exposição a Multa	Risco Elevado	Risco Baixo
Pronto p/ Auditoria	Não	Sim

O Próximo Passo é Personalizado

Esta checklist deu-lhe o panorama geral. Mas cada organização tem o seu perfil de risco único, a sua arquitectura tecnológica, os seus fornecedores específicos e as suas vulnerabilidades particulares.

O NIS2 Readiness Assessment da Dalpin Heritage vai mais fundo:

	Auditoria técnica e documental completa Análise de todos os 10 domínios com evidências reais
	Relatório PDF executivo (10–15 páginas) Resumo para o Conselho + detalhe técnico para o CISO
	Matriz de risco personalizada Priorização dos investimentos por impacto e urgência
	Plano de acção com 90 dias Roadmap realista com milestones, responsáveis e KPIs
	Carta de conformidade Documento para apresentar a reguladores e parceiros

■ Agende a sua Consultoria Diagnóstica Gratuita

30 minutos. Sem compromisso. Com uma avaliação preliminar do seu nível de conformidade.

■ DHS — Systems ■ nash@dalpinheritage.com	■ Agendar Meeting: https://book.morgen.so/nashdalpin791/nas	■ +351 934 032 320 Seg–Sex, 09:00–18:00
--	--	---

Este documento é fornecido para fins informativos e não constitui aconselhamento jurídico. Para uma avaliação completa de conformidade NIS2 da sua organização, consulte um especialista qualificado. © 2026. DHS - Systems. Todos os direitos reservados.